Cod. Corso A757- 12-2024-0
ID Attività 2584660

Insegnamento: DAO

Prof. Silvio Meneguzzo

MODULE

Decentralized Autonomous Organizations (DAO)

On-chain governance: token-weighted voting, treasuries, timelocks and the attacks that target them — mechanics, real cases, a Remix lab, and tooling

Blockchain and Distributed Ledger Technologies

Course module — Blockchain & DLT · CYBER 2026

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

Outline

I · Foundations

What a DAO is, the on-chain stack, DAO vs a traditional organization.

II · How it works

Governance tokens, voting power, and the life of a proposal.

III · Mechanics & attacks

Quorum, timelocks, voting schemes, and governance exploits.

IV · Lab

Build propose / vote / execute over a treasury in Remix.

V · Real DAOs & tooling

MakerDAO, Uniswap, Compound; OZ Governor, Snapshot, Safe.

VI · References

Standards, frameworks and incident post-mortems.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

PART I

Foundations

What a DAO is — an organization whose rules live in code, not in a registrar

COESIONE ITALIA 21-27 PIEMONTE
Cofinanziato dall'Unione europea
REGIONE PIEMONTE

What is a DAO?

A Decentralized Autonomous Organization coordinates people and capital through smart-contract rules and token-based voting — no central board, no bank.

Rules as code

Membership, proposals and the treasury are governed by public, immutable contracts anyone can audit.

Member-owned

Token holders — not managers — decide. Voting power is usually proportional to tokens held or delegated.

Autonomous execution

A passed proposal executes itself on-chain: the contract moves funds or changes a parameter, trustlessly.

Transparent treasury

Funds sit in a contract, not a bank account. Every inflow and outflow is visible on-chain in real time.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

DAO vs traditional organization

Traditional org

Authority flows top-down; a board and officers act; bank and registrar are trusted intermediaries; decisions and books are private.

DAO

Authority is token-weighted and bottom-up; contracts execute decisions; the treasury is on-chain; proposals, votes and funds are public.

Trade-off: a DAO gains transparency, global permissionless participation and self-execution — but loses the speed of a single decision-maker and the legal clarity of a company.

Key idea: a DAO replaces 'trust the managers' with 'verify the code and the vote'.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

The on-chain DAO stack

Most modern DAOs compose four standard contracts. The Remix lab implements a minimal version of all four.

Governance token

An ERC-20 (often ERC20Votes) whose balance = voting power, and which can be delegated to another address.

Governor

Runs the proposal lifecycle: propose, vote, tally against quorum, and mark a proposal succeeded or defeated.

Timelock

Queues a passed proposal for a fixed delay before execution, giving members time to react or exit.

Treasury

The contract that holds the funds. Only the Governor / Timelock can move them, and only via a passed proposal.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

PART II

How a DAO works on-chain

Governance tokens, voting power, and the life of a proposal

Governance tokens & voting power

Voting power comes from tokens. HOW you measure it decides who really controls the DAO — and whether it can be attacked.

Token-weighted

1 token = 1 vote. Simple and Sybil-resistant, but wealth-weighted: a whale can dominate.

Delegation

Holders delegate voting power to an active representative without transferring the tokens.

Snapshots (checkpoints)

Voting power is frozen at the proposal's creation block, so tokens bought AFTER a proposal carry no weight.

Why it matters

Without snapshots an attacker can flash-borrow tokens, vote, and repay in one transaction (see Beanstalk).

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

The life of a proposal

1 · Pending

Created; voting has not opened yet (an optional delay after creation).

2 · Active

Voting is open; holders cast For / Against, weighted by their snapshot power.

3 · Succeeded / Defeated

At the deadline: passes iff quorum is met AND For > Against; else defeated.

4 · Queued

A succeeded proposal enters the timelock and waits out the delay.

5 · Executed

After the delay, anyone can execute it; the contract performs the on-chain action.

6 · Cancelled / Expired

A proposal can be cancelled (e.g. by a guardian) or expire if never executed in time.

The three core calls (from the lab)

A minimal Governor exposes exactly three entry points. The lab implements them over an ETH treasury.

SimpleDAO.sol

```
function propose(address target, uint256 value,
                 bytes data, string description) returns (uint256 id);

function vote(uint256 id, bool support);   // weight = token balance

function execute(uint256 id);              // after voting + timelock
```

A passed proposal makes the DAO ITSELF call `target` with `data`, moving `value` wei from its treasury.

Quorum, threshold and turnout

Two independent gates decide whether a proposal passes — and a third stops spam.

Quorum

A minimum total voting power that must participate, so a tiny turnout cannot move the treasury.

Approval threshold

Of the votes cast, the rule to pass — usually simple majority (For > Against), sometimes a supermajority.

Proposal threshold

A minimum token balance required to CREATE a proposal, to stop spam.

Turnout problem

Most holders never vote. Low participation concentrates real power in a few large, active voters.

Why a timelock?

Without a timelock

A passed proposal executes instantly. A malicious or buggy proposal drains the treasury before anyone can react.

With a timelock

Execution waits a fixed delay (e.g. 1-2 days). Members can inspect the queued action and exit or organize against it.

The timelock does not judge whether a proposal is good — it only buys TIME. It is the single most important safety mechanism in DAO governance.

Key idea: pass ≠ execute. Between them sits a delay that turns a silent exploit into a public, contestable event.

COESIONE ITALIA 21-27 PIEMONTE
Cofinanziato dall'Unione europea
REGIONE PIEMONTE

PART III

Governance mechanics & attacks

Voting schemes, and how whoever controls the vote controls the treasury

COESIONE ITALIA 21-27 PIEMONTE
Cofinanziato dall'Unione europea
REGIONE PIEMONTE

Beyond 1-token-1-vote

Token-weighting is simple but plutocratic. Alternative schemes trade simplicity for fairer influence.

Token-weighted

Power is proportional to tokens. Easy and Sybil-resistant, but the richest holders decide.

Quadratic voting

Cost grows with the SQUARE of votes, so concentrated wealth buys less marginal influence — but needs identity / Sybil resistance.

Conviction voting

Voting power grows the longer you keep backing a proposal, rewarding sustained conviction over snap votes.

Delegation / liquid democracy

Delegate to experts you trust and reclaim anytime — raising effective turnout.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

How DAO governance gets attacked

Governance is an attack surface: whoever controls the vote controls the treasury.

Flash-loan vote-buying

Borrow a huge amount of governance tokens, vote, repay — all in one tx. Defeated by snapshots. (Beanstalk, 2022.)

Governance capture

A whale or colluding group accumulates enough tokens to pass proposals unilaterally.

Low-turnout takeover

When almost nobody votes, a small stake can meet quorum and pass a self-serving proposal.

Malicious proposal

Calldata that looks benign but grants control or drains funds. Timelocks expose it before it fires.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

Case study — Beanstalk (April 2022)

The exploit

The attacker took a ~$1B flash loan from Aave, converted it into Beanstalk governance tokens, and gained a supermajority in a single transaction.

The payload

With that instant majority they passed a malicious 'emergency' proposal that transferred ~$182M of protocol funds to themselves, then repaid the loan.

Root cause: voting power was counted at vote time, and an emergency path let a supermajority execute immediately — no snapshot, no timelock.

Key lesson: snapshot voting power at proposal creation, and never allow instant execution without a delay.

Defending DAO governance

The Beanstalk pattern is preventable with standard, composable safeguards.

Snapshot at creation

Measure voting power at the proposal's start block (ERC20Votes / getPastVotes). Flash-loaned tokens carry no weight.

Timelock every action

No proposal executes instantly. A delay turns a silent drain into a public, contestable event.

Quorum + proposal threshold

Require real participation to pass, and a real stake to propose — raising the cost of an attack.

Guardian / veto

A limited, accountable role that can cancel a clearly-malicious queued proposal during the timelock.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

PART IV

Lab — build a DAO

Propose, vote and execute over a treasury, in Remix

COESIONE ITALIA 21-27 PIEMONTE
Cofinanziato dall'Unione europea
REGIONE PIEMONTE

LAB — DO IT NOW

Build propose / vote / execute over a treasury

Open the folder lab-dao/ in Remix (VM). Complete vote and the pass/quorum check in 01-SimpleDAO_start.sol, then run the full flow: fund the treasury, propose a payment, vote, wait out the timing, execute.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

[0x0ce878f44103BEd75740a97443ECb2aBA5c53304](0x0ce878f44103BEd75740a97443ECb2aBA5c53304)

GovToken

0xA15fACC43FBE5AEdD086874B13386A24d5a81714

SimpleDAO

Lab solution — vote and execute

Weight each vote by the caller's token balance; pass on majority AND quorum; execute follows Checks-Effects-Interactions.

SimpleDAO.sol

```
function vote(uint256 id, bool support) external {
  require(block.timestamp <= p.endTime && !hasVoted[id][msg.sender]);
  uint256 w = token.balanceOf(msg.sender);        // voting power
  hasVoted[id][msg.sender] = true;
  if (support) p.forVotes += w; else p.againstVotes += w;
}
// in execute():
bool passed = p.forVotes > p.againstVotes && p.forVotes >= quorumVotes;
p.executed = true;                                  // EFFECT first
(bool ok,) = p.target.call{value: p.value}(p.data);// INTERACTION last
```

`executed` is set BEFORE the external call, so a proposal can never be run twice or re-entered.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

What the lab shows — and its deliberate flaw

The minimal DAO works end-to-end, but it weights votes by balance-at-vote-time. That is exactly the Beanstalk hole.

Timelock in action

execute() reverts until the voting period AND the timelock delay have elapsed — pass is not execute.

Quorum in action

A proposal only a small holder supports fails: forVotes < quorumVotes → ProposalRejected.

The flaw to fix

balanceOf at vote time is flash-loan-attackable: borrow tokens, vote, repay in one tx.

The production fix

OpenZeppelin ERC20Votes snapshots power at proposal creation; Governor + TimelockController wire it together.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

PART V

Real DAOs & tooling

Who runs on this — and the frameworks you actually compose

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

DAOs in the wild

A non-exhaustive map; the space moves fast.

Protocol DAOs

MakerDAO / Sky (MKR), Uniswap (UNI), Compound (COMP), Aave — govern DeFi parameters and treasuries.

Grant / public-goods DAOs

Gitcoin (quadratic funding) and the Optimism Collective fund ecosystem work.

Collector / social DAOs

Nouns DAO (one NFT = one vote, daily auctions); ENS DAO governs the naming system.

The original

'The DAO' (2016) raised ~$150M in ETH; a reentrancy hack led to the ETH / ETC hard fork.

Governance tooling

You almost never write a Governor from scratch — you compose audited frameworks.

OpenZeppelin Governor

The de-facto on-chain standard: Governor + ERC20Votes + TimelockController, modular and audited.

Compound Governor Bravo

The battle-tested design many protocols forked; snapshots votes via getPriorVotes.

Snapshot (off-chain)

Gasless, signature-based voting for signalling; results often executed on-chain by a Safe multisig.

Tally · Aragon · Safe

Tally (governance UI), Aragon (DAO framework), Safe (multisig treasury) round out the stack.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

The honest picture: law and practice

'Decentralized' is a spectrum

Many DAOs still rely on a core team, a multisig, or a tiny active-voter base. Progressive decentralization is a goal, not a given.

Legal status is unsettled

Wyoming (2021) and others created DAO-LLC wrappers, but liability, taxation and enforceability remain open questions.

The DAO fork (2016) showed governance can override 'immutable' code when enough of the community agrees — a social layer sits under the technical one.

Key idea: read WHO can actually move the treasury — the code, the multisig signers, and the real voter distribution.

Key takeaways

- A DAO is rules-as-code — token-weighted voting over an on-chain treasury, with no central board.
- The standard stack is four contracts — governance token, Governor, timelock, treasury.
- Pass ≠ execute — a timelock delay between them is the single most important safeguard.
- Measure voting power at proposal creation — snapshots defeat flash-loan vote-buying (Beanstalk).
- Quorum + proposal threshold — require real turnout to pass and a real stake to propose.
- Compose audited tooling — OpenZeppelin Governor / ERC20Votes / TimelockController, Snapshot, Safe.

GROUP PROJECT

Design a system — work in teams

In teams of 2-3, design (on paper) a small on-chain system that uses one or more of the topics we have covered. Goal: think like an architect — pick a problem, choose the right primitives, and defend your design against attacks. The next slide has ideas and tips.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

Group project — ideas & tips

Fair on-chain game

Use commit-reveal to build a sealed-bid auction or a lottery where no one can see or front-run others' inputs.

Safe vault / staking

A deposit/withdraw vault applying CEI + a reentrancy guard, pull-payments and access control (Ownable).

Mini-AMM or lending

A 2-token pool ($x\cdot y=k$) or an overcollateralized loan with a liquidation rule and a keeper incentive.

Oracle-safe pricing

Consume a price feed with positivity + freshness checks, or a TWAP; explain how you resist flash-loan manipulation.

Micro-DAO

A governance token + propose/vote/execute over a treasury, with a timelock and snapshot voting against flash-loan vote-buying.

Tips & deliverable

Draw the contracts & state machine; list 3 attacks and your defence for each; state the trust assumptions. 5-minute pitch per team.

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

PART VI

References

Standards, frameworks and incident post-mortems

References

[1] OpenZeppelin Governance — Governor, ERC20Votes, TimelockController. docs.openzeppelin.com/contracts/api/governance

[2] Compound Governance — Governor Bravo & GovernorAlpha. docs.compound.finance/v2/governance

[3] MakerDAO / Sky governance documentation. docs.sky.money

[4] Snapshot — off-chain, gasless, signature-based voting. docs.snapshot.box

[5] Aragon (DAO framework) & Safe (multisig treasury). aragon.org · safe.global

[6] Beanstalk flash-loan governance exploit (Apr 2022) — post-mortems. rekt.news

[7] 'The DAO' (2016) and the ETH / ETC hard fork — analyses. ethereum.org · coindesk.com

[8] Wyoming DAO LLC Act (2021); V. Buterin — 'DAOs are not corporations' (2022). vitalik.eth.limo

COESIONE ITALIA 21-27 PIEMONTE | Cofinanziato dall'Unione europea | REGIONE PIEMONTE

Questions?

A DAO is only as decentralized as its voter distribution and as safe as its timelock. Verify who can move the treasury — then trust the vote.

Grazie per l’attenzione